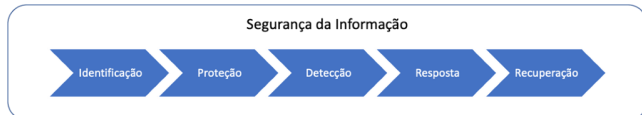


Introdução à Segurança da Informação

terça-feira, 31 de março de 2026 08:51

Princípios de Segurança da Informação

- A segurança da informação tem como objetivo proteger dados contra diferentes tipos de ameaças, garantindo a continuidade dos negócios, reduzindo danos e maximizando oportunidades e investimentos. Além disso, envolve um conjunto de processos contínuos: **identificação, proteção, detecção, resposta e recuperação**, formando um ciclo completo de defesa e gestão da informação.



Normas e Padronização

Os princípios da segurança da informação são definidos internacionalmente por normas da **ISO (International Organization for Standardization)** e da **IEC (International Electrotechnical Commission)**. No Brasil, essas normas são adotadas e regulamentadas pela **ABNT (Associação Brasileira de Normas Técnicas)**, principalmente por meio das normas:

- **ABNT NBR ISO/IEC 27001**
- **ABNT NBR ISO/IEC 27002**

Essas normas orientam as organizações na criação e gestão de um **Sistema de Gestão de Segurança da Informação (SGSI)**, incluindo etapas como implementação, operação, monitoramento e melhoria contínua.

Tríade da Segurança da Informação (CID)

A base da segurança da informação é formada pela tríade **CID**, composta por três princípios fundamentais:

1. Confidencialidade

Refere-se à proteção da informação contra acesso não autorizado.

Garante que apenas pessoas, sistemas ou entidades autorizadas possam acessar determinados dados.

2. Integridade

Está relacionada à preservação da exatidão e completude das informações.

Assegura que os dados não sejam alterados de forma indevida ou não autorizada.

3. Disponibilidade

Refere-se ao acesso à informação sempre que necessário.

Garante que sistemas e dados estejam disponíveis no momento adequado para os usuários autorizados.

Propriedades Complementares

Com o tempo, a tríade CID foi ampliada com outros princípios importantes:

4. Autenticidade

Garante que uma pessoa ou sistema é realmente quem afirma ser.

Está diretamente ligada a mecanismos de autenticação, como senhas e biometria.

5. Não-Repúdio (Irretratabilidade)

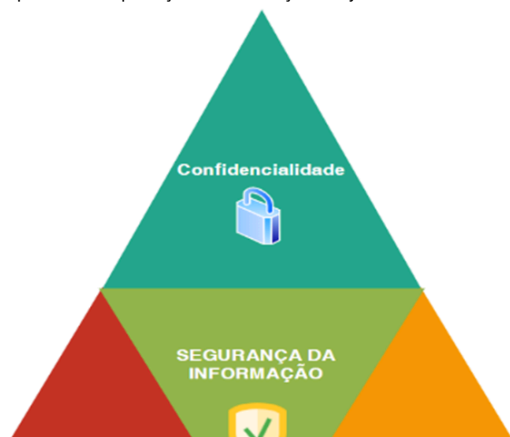
Assegura que um usuário não possa negar a autoria de uma ação ou informação.

É fundamental em transações digitais e registros eletrônicos.

6. Legalidade

Relaciona-se ao cumprimento de leis, normas e regulamentações aplicáveis.

Garante que o uso e a proteção da informação estejam de acordo com a legislação vigente.



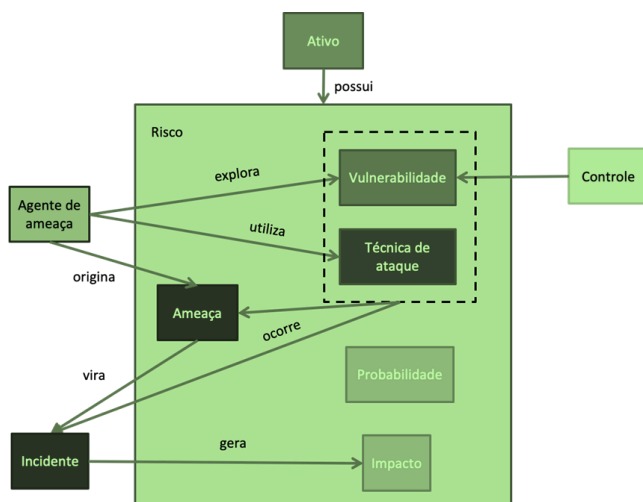


Importância Geral

- Esses princípios formam a base da segurança da informação nas organizações.
- Servem como guia para definição de objetivos e políticas de segurança em TI.
- Contribuem para a proteção dos dados, continuidade dos serviços e confiança nos sistemas.
- São essenciais para prevenir riscos, minimizar impactos e garantir conformidade legal.

Fundamentos de Segurança da Informação

Além dos princípios, a segurança da informação envolve conceitos fundamentais que orientam toda a gestão e proteção dos dados dentro de uma organização. Esses conceitos são definidos principalmente pelas normas **ABNT NBR ISO/IEC 27001** e **27002**.



Conceitos Essenciais

Informação

A informação é um **ativo valioso** para a organização, assim como qualquer outro recurso importante para o negócio. Por isso, deve ser devidamente protegida contra ameaças e acessos indevidos.

Ativo

É qualquer elemento que possui valor para a organização.

Pode incluir:

- Informações
- Equipamentos (hardware)
- Sistemas
- Pessoas

Ameaças e Vulnerabilidades

Agente de ameaça

É quem realiza o ataque, explorando vulnerabilidades de forma intencional.

Técnica de ataque

São os métodos ou padrões utilizados por agentes de ameaça para explorar falhas e comprometer sistemas.

Ameaça

É uma **causa potencial de incidente**, podendo gerar danos à organização.

Só existe efetivamente quando há vulnerabilidades que possam ser exploradas.

Vulnerabilidade

É um **ponto fraco** em um sistema, pessoa ou processo.

Quando explorada, pode resultar em um incidente de segurança.

- Pode existir em diferentes níveis:
- Humanos (ex: falta de treinamento)
- Físicos (ex: acesso não controlado)
- Tecnológicos (ex: falhas em sistemas, redes, softwares)
- Regra importante:

ataques acontecem onde existem vulnerabilidades

Controles e Gestão de Riscos

Controles

São mecanismos de defesa utilizados para reduzir ou eliminar vulnerabilidades.

Tipos de controles:

- Físicos (ex: controle de acesso a ambientes)
- Tecnológicos (ex: firewalls, antivírus)
- Processuais (ex: políticas e normas internas)

Risco

É a **probabilidade de uma ameaça explorar uma vulnerabilidade**, gerando um incidente e causando impactos à organização.

- Redução de risco:
- Identificar vulnerabilidades
- Aplicar controles adequados
- Monitorar continuamente

Eventos e Incidentes

Evento de segurança da informação

Indica uma possível violação ou comportamento fora do padrão das políticas de segurança.

Incidente de segurança da informação

É um evento confirmado que pode comprometer operações, sistemas ou dados.

Impacto

É o resultado causado por um incidente, podendo afetar:

- Operações
- Financeiro
- Reputação da empresa

Elementos a Serem Protegidos

A segurança da informação não protege apenas dados, mas três grandes grupos:

1. Pessoas

- Podem ser alvo de ataques como:
- Engenharia social
- Manipulação
- Suborno
- São consideradas um dos pontos mais vulneráveis

2. Ativos

- **Físicos:** computadores, servidores, instalações
- **Tecnológicos:** sistemas, softwares, aplicações

3. Informação

- É o principal elemento a ser protegido
- Circula entre pessoas e sistemas, exigindo proteção em todas as etapas

Visão Geral

- A segurança da informação depende da identificação de **ativos, ameaças e vulnerabilidades**
- O uso de **controles adequados** reduz riscos
- Incidentes podem gerar impactos significativos se não forem prevenidos
- A proteção deve abranger **pessoas, ativos e informação de forma integrada**